Étude de cas, Mise en place de GCE

Dans ce chapitre, nous entrerons dans la phase pratique de notre étude en définissant nos objectifs et en décrivant l'environnement que nous avons mis en place. Nous expliquerons également le processus d'installation de l'outil et les étapes de configuration de Greenbone Community Edition.

1.1. Objectifs

Le but de cette implémentation est de mettre en place une solution capable de répondre efficacement aux besoins de gestion des vulnérabilités au sein de notre environnement informatique, sa fonctionnalité de base étant de réaliser des scans performants, d'identifier les vulnérabilités, de les classer en fonction de leur sévérité et de fournir des rapports exhaustifs avec des possibilités de remédiation.

1.2. Description de l'environnement mis en place

Afin d'exploiter les différentes fonctionnalités de GCE, le déploiement se fera dans un environnement dédié représentatif.

Pour l'implémentation de GCE, nous avons mis en place un serveur Ubuntu dédié 22.05 LTS qui respecte les exigences matérielles suivantes :

- CPU Cores : 4
- Mémoire : 8Gb
- Disque : 60Gb

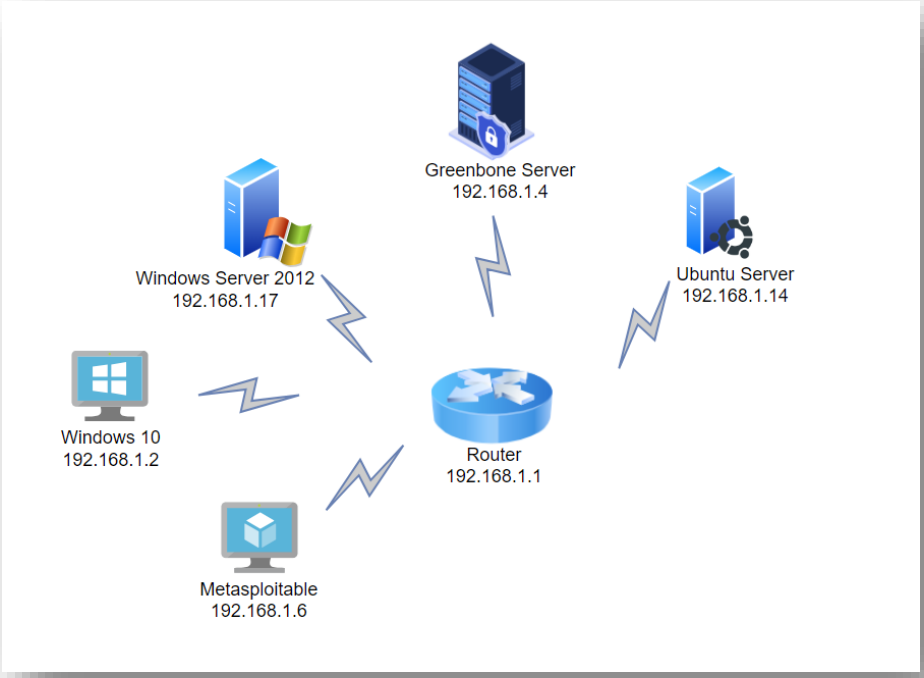


Figure 1: Architecture de test

Assets	Adresses IP
Metasploitable	192.168.1.6
Windows Server 2012	192.168.1.17
Windows 10	192.168.1.2
GCE	192.168.1.4
Ubuntu Server	192.168.1.14

Tableau 1: Liste des différents assets

1.3. Installation de l'outil

L'implémentation consistera à mettre en place la solution GCE à partir du code source GSE[1].

Nous avons pris cette décision pour plusieurs raisons :

Dernières Fonctionnalités : En optant pour l'installation à partir du code source, nous avons accès aux dernières fonctionnalités et correctifs dès leur publication par la communauté Greenbone. Cela garantit que notre installation est à jour et capable de gérer les vulnérabilités les plus récentes.

Contrôle des Versions : Nous pouvons choisir les versions spécifiques des composants et des dépendances qui sont compatibles avec notre infrastructure. Cela évite les conflits de dépendances et garantit la stabilité de notre installation.

Apprentissage : L'installation à partir du code source nous offre également une opportunité d'apprentissage précieuse. Nous acquérons des compétences en compilation, en gestion des dépendances et en résolution de problèmes.

- **Mise à jour du système**

Pour commencer, nous allons mettre à jour et à niveau les différents packages du système :

```
Apt-get update
Apt-get upgrade
```

- **Création d'un utilisateur et d'un groupe**

```
sudo useradd -r -M -U -G sudo -s /usr/sbin/nologin gvm
sudo usermod -aG gvm $USER
su $USER
```

[1] Voir Webographie, [W8]

```
sudo apt install --no-install-recommends --assume-yes \
  build-essential \
  curl \
  cmake \
  pkg-config \
  python3 \
  python3-pip \
  gnupg
```

Pour valider l'intégrité des fichiers sources téléchargés, GnuPG est utilisé. Cela nécessite de télécharger la clé publique Greenbone Community Signing et de l'importer dans le trousseau de l'utilisateur actuel.

```
curl -f -L https://www.greenbone.net/GBCommunitySigningKey.asc -o
/tmp/GBCommunitySigningKey.asc

gpg --import /tmp/GBCommunitySigningKey.asc

echo "8AE4BE429B60A59B311C2E739823FAA60ED1E580:6:" | gpg --import-ownertrust
```

- **Installation des composants**

Installation de gvm-libs

```
export GVM_LIBS_VERSION=22.7.1

curl -f -L https://github.com/greenbone/gvm-
libs/archive/refs/tags/v$GVM_LIBS_VERSION.tar.gz -o $SOURCE_DIR/gvm-libs-
$GVM_LIBS_VERSION.tar.gz

curl -f -L https://github.com/greenbone/gvm
libs/releases/download/v$GVM_LIBS_VERSION/gvm-libs-
v$GVM_LIBS_VERSION.tar.gz.asc -o $SOURCE_DIR/gvm-libs-
$GVM_LIBS_VERSION.tar.gz.asc

gpg --verify $SOURCE_DIR/gvm-libs-$GVM_LIBS_VERSION.tar.gz.asc
$SOURCE_DIR/gvm-libs-$GVM_LIBS_VERSION.tar.gz

tar -C $SOURCE_DIR -xvzf $SOURCE_DIR/gvm-libs-$GVM_LIBS_VERSION.tar.gz
```

```
mkdir -p $BUILD_DIR/gvm-libs && cd $BUILD_DIR/gvm-libs

cmake $SOURCE_DIR/gvm-libs-$GVM_LIBS_VERSION \

  -DCMAKE_INSTALL_PREFIX=$INSTALL_PREFIX \

  -DCMAKE_BUILD_TYPE=Release \

  -DSYSCONFDIR=/etc \

  -DLOCALSTATEDIR=/var

make -j$(nproc)

mkdir -p $INSTALL_DIR/gvm-libs

make DESTDIR=$INSTALL_DIR/gvm-libs install

sudo cp -rv $INSTALL_DIR/gvm-libs/* /
```

Installation de gvmd

```
export GVMD_VERSION=22.9.0

curl -f -L https://github.com/greenbone/gvmd/archive/refs/tags/v$GVMD_VERSION.tar.gz -o $SOURCE_DIR/gvmd-$GVMD_VERSION.tar.gz

curl -f -L https://github.com/greenbone/gvmd/releases/download/v$GVMD_VERSION/gvmd-$GVMD_VERSION.tar.gz.asc -o $SOURCE_DIR/gvmd-$GVMD_VERSION.tar.gz.asc

gpg --verify $SOURCE_DIR/gvmd-$GVMD_VERSION.tar.gz.asc $SOURCE_DIR/gvmd-$GVMD_VERSION.tar.gz

tar -C $SOURCE_DIR -xvzf $SOURCE_DIR/gvmd-$GVMD_VERSION.tar.gz

mkdir -p $BUILD_DIR/gvmd && cd $BUILD_DIR/gvmd

cmake $SOURCE_DIR/gvmd-$GVMD_VERSION \

  -DCMAKE_INSTALL_PREFIX=$INSTALL_PREFIX \

  -DCMAKE_BUILD_TYPE=Release \

  -DLOCALSTATEDIR=/var \

  -DSYSCONFDIR=/etc \

  -DGVM_DATA_DIR=/var \

  -DGVMD_RUN_DIR=/run/gvmd \
```

```
-DGVMD_RUN_DIR=/run/gvmd \
-DOPENVAS_DEFAULT_SOCKET=/run/ospd/ospd-openvas.sock \
-DGVM_FEED_LOCK_PATH=/var/lib/gvm/feed-update.lock \
-DSYSTEMD_SERVICE_DIR=/lib/systemd/system \
-DLOGROTATE_DIR=/etc/logrotate.d
```

```
make -j$(nproc)
mkdir -p $INSTALL_DIR/gvmd
make DESTDIR=$INSTALL_DIR/gvmd install
sudo cp -rv $INSTALL_DIR/gvmd/* /
```

Installation de Greenbone Security Assistant

Les sources de Greenbone Security Assistant (GSA) se composent de deux parties : Serveur Web gsad et Application Web GSA.

GSA:

```
export GSA_VERSION=22.7.1
curl -f -L https://github.com/greenbone/gsa/releases/download/v$GSA_VERSION/gsa-dist-$GSA_VERSION.tar.gz -o $SOURCE_DIR/gsa-$GSA_VERSION.tar.gz
curl -f -L https://github.com/greenbone/gsa/releases/download/v$GSA_VERSION/gsa-dist-$GSA_VERSION.tar.gz.asc -o $SOURCE_DIR/gsa-$GSA_VERSION.tar.gz.asc
gpg --verify $SOURCE_DIR/gsa-$GSA_VERSION.tar.gz.asc $SOURCE_DIR/gsa-$GSA_VERSION.tar.gz
mkdir -p $SOURCE_DIR/gsa-$GSA_VERSION
tar -C $SOURCE_DIR/gsa-$GSA_VERSION -xvzf $SOURCE_DIR/gsa-$GSA_VERSION.tar.gz
sudo mkdir -p $INSTALL_PREFIX/share/gvm/gsad/web/
sudo cp -rv $SOURCE_DIR/gsa-$GSA_VERSION/* $INSTALL_PREFIX/share/gvm/gsad/web/
```

Gsad:

```
export GSAD_VERSION=22.6.0

sudo apt install -y \

  libmicrohttpd-dev \

  libxml2-dev \

  libglib2.0-dev \

  libgnutls28-dev
```

```
curl -f -L https://github.com/greenbone/gsad/archive/refs/tags/v$GSAD_VERSION.tar.gz -o
$SOURCE_DIR/gsad-$GSAD_VERSION.tar.gz

curl -f -L https://github.com/greenbone/gsad/releases/download/v$GSAD_VERSION/gsad-
$GSAD_VERSION.tar.gz.asc -o $SOURCE_DIR/gsad-$GSAD_VERSION.tar.gz.asc

gpg --verify $SOURCE_DIR/gsad-$GSAD_VERSION.tar.gz.asc $SOURCE_DIR/gsad-
$GSAD_VERSION.tar.gz

tar -C $SOURCE_DIR -xvzf $SOURCE_DIR/gsad-$GSAD_VERSION.tar.gz

mkdir -p $BUILD_DIR/gsad && cd $BUILD_DIR/gsad

cmake $SOURCE_DIR/gsad-$GSAD_VERSION \

  -DCMAKE_INSTALL_PREFIX=$INSTALL_PREFIX \

  -DCMAKE_BUILD_TYPE=Release \

  -DSYSCONFDIR=/etc \

  -DLOCALSTATEDIR=/var \

  -DGVMD_RUN_DIR=/run/gvmd \

  -DGSAD_RUN_DIR=/run/gsad \

  -DLOGROTATE_DIR=/etc/logrotate.d

make -j$(nproc)

mkdir -p $INSTALL_DIR/gsad

make DESTDIR=$INSTALL_DIR/gsad install

sudo cp -rv $INSTALL_DIR/gsad/* /
```

Installation de Openvas-smb

```
export OPENVAS_SMB_VERSION=22.5.3

curl -f -L https://github.com/greenbone/openvas-smb/archive/refs/tags/v$OPENVAS_SMB_VERSION.tar.gz -o $SOURCE_DIR/openvas-smb-$OPENVAS_SMB_VERSION.tar.gz

curl -f -L https://github.com/greenbone/openvas-smb/releases/download/v$OPENVAS_SMB_VERSION/openvas-smb-v$OPENVAS_SMB_VERSION.tar.gz.asc -o $SOURCE_DIR/openvas-smb-$OPENVAS_SMB_VERSION.tar.gz.asc

gpg --verify $SOURCE_DIR/openvas-smb-$OPENVAS_SMB_VERSION.tar.gz.asc $SOURCE_DIR/openvas-smb-$OPENVAS_SMB_VERSION.tar.gz

tar -C $SOURCE_DIR -xvzf $SOURCE_DIR/openvas-smb-$OPENVAS_SMB_VERSION.tar.gz
```

```
mkdir -p $BUILD_DIR/openvas-smb && cd $BUILD_DIR/openvas-smb

cmake $SOURCE_DIR/openvas-smb-$OPENVAS_SMB_VERSION \

  -DCMAKE_INSTALL_PREFIX=$INSTALL_PREFIX \

  -DCMAKE_BUILD_TYPE=Release

make -j$(nproc)

mkdir -p $INSTALL_DIR/openvas-smb

make DESTDIR=$INSTALL_DIR/openvas-smb install

sudo cp -rv $INSTALL_DIR/openvas-smb/* /
```

Installation de Openvas-scanner

```
export OPENVAS_SCANNER_VERSION=22.7.5

sudo apt install -y \

  bison \ libglib2.0-dev \  libgnutls28-dev \

  libgcrypt20-dev \ libpcap-dev \ libgpgme-dev \ libksba-dev \ rsync \

  nmap \ libjson-glib-dev \

  libbsd-dev sudo apt install -y \python3-impacket \libsnmp-dev
```

```
curl -f -L https://github.com/greenbone/openvas-scanner/archive/refs/tags/v$OPENVAS_SCANNER_VERSION.tar.gz -o $SOURCE_DIR/openvas-scanner-$OPENVAS_SCANNER_VERSION.tar.gz

curl -f -L https://github.com/greenbone/openvas-scanner/releases/download/v$OPENVAS_SCANNER_VERSION/openvas-scanner-v$OPENVAS_SCANNER_VERSION.tar.gz.asc -o $SOURCE_DIR/openvas-scanner-$OPENVAS_SCANNER_VERSION.tar.gz.asc

gpg --verify $SOURCE_DIR/openvas-scanner-$OPENVAS_SCANNER_VERSION.tar.gz.asc $SOURCE_DIR/openvas-scanner-$OPENVAS_SCANNER_VERSION.tar.gz

tar -C $SOURCE_DIR -xvzf $SOURCE_DIR/openvas-scanner-$OPENVAS_SCANNER_VERSION.tar.gz

mkdir -p $BUILD_DIR/openvas-scanner && cd $BUILD_DIR/openvas-scanner

cmake $SOURCE_DIR/openvas-scanner-$OPENVAS_SCANNER_VERSION \

  -DCMAKE_INSTALL_PREFIX=$INSTALL_PREFIX \

  -DCMAKE_BUILD_TYPE=Release \

  -DINSTALL_OLD_SYNC_SCRIPT=OFF \

  -DSYSCONFDIR=/etc \

  -DLOCALSTATEDIR=/var \

  -DOPENVAS_FEED_LOCK_PATH=/var/lib/openvas/feed-update.lock \

  -DOPENVAS_RUN_DIR=/run/ospd

make -j$(nproc)

mkdir -p $INSTALL_DIR/openvas-scanner

make DESTDIR=$INSTALL_DIR/openvas-scanner install

sudo cp -rv $INSTALL_DIR/openvas-scanner/* /
```

Installation de Greenbone-feed-sync

L'outil greenbone-feed-sync est un script basé sur Python permettant de télécharger toutes les données de flux du flux communautaire Greenbone sur un ordinateur local. Il s'agit d'une version améliorée de deux anciens scripts shell.

```
sudo apt install -y \
  python3 \
  python3-pip
mkdir -p $INSTALL_DIR/greenbone-feed-sync
python3 -m pip install --root=$INSTALL_DIR/greenbone-feed-sync --no-warn-script-location greenbone-feed-sync
sudo cp -rv $INSTALL_DIR/greenbone-feed-sync/* /
```

Installation de Gvm-tools

Les outils de gestion des vulnérabilités Greenbone, ou gvm-tools en abrégé, sont un ensemble d'outils qui aident à contrôler les installations de Greenbone Community Edition ou les appareils Greenbone Enterprise à distance.

Essentiellement, les outils facilitent l'accès aux protocoles de communication Greenbone Management Protocol (GMP) et Open Scanner Protocol (OSP).

Les outils gvm sont facultatifs et ne sont pas requis pour une pile GVM fonctionnelle.

```
sudo apt install -y \
  python3 \
  python3-pip \
  python3-venv \
  python3-setuptools \
  python3-packaging \
  python3-lxml \
  python3-defusedxml \
  python3-paramiko
mkdir -p $INSTALL_DIR/gvm-tools
python3 -m pip install --root=$INSTALL_DIR/gvm-tools --no-warn-script-location gvm-tools
sudo cp -rv $INSTALL_DIR/gvm-tools/* /
```

- **Exécution du Setup système**

Configuration du Data Store Redis

En regardant l'architecture, le stockage clé/valeur Redis est utilisé par le scanner (openvas-scanner et ospd-openvas) pour gérer les informations VT et les résultats de l'analyse.

```
sudo apt install -y redis-server
sudo cp $SOURCE_DIR/openvas-scanner-$OPENVAS_SCANNER_VERSION/config/redis-openvas.conf /etc/redis/
sudo chown redis:redis /etc/redis/redis-openvas.conf
echo "db_address = /run/redis-openvas/redis.sock" | sudo tee -a /etc/openvas/openvas.conf
sudo systemctl start redis-server@openvas.service
sudo systemctl enable redis-server@openvas.service
sudo usermod -aG redis gvm
```

Ajustement des permissions

```
sudo mkdir -p /var/lib/notus

sudo mkdir -p /run/gvmd

sudo chown -R gvm:gvm /var/lib/gvm

sudo chown -R gvm:gvm /var/lib/openvas

sudo chown -R gvm:gvm /var/lib/notus

sudo chown -R gvm:gvm /var/log/gvm

sudo chown -R gvm:gvm /run/gvmd

sudo chmod -R g+srw /var/lib/gvm

sudo chmod -R g+srw /var/lib/openvas

sudo chmod -R g+srw /var/log/gvm

sudo chown gvm:gvm /usr/local/sbin/gvmd

sudo chmod 6750 /usr/local/sbin/gvmd
```

Validation du flux

Pour valider le contenu du flux, un trousseau GnuPG avec la clé d'intégrité Greenbone Community Feed doit être créé.

```
curl -f -L https://www.greenbone.net/GBCommunitySigningKey.asc -o
/tmp/GBCommunitySigningKey.asc

export GNUPGHOME=/tmp/openvas-gnupg

mkdir -p $GNUPGHOME

gpg --import /tmp/GBCommunitySigningKey.asc

echo "8AE4BE429B60A59B311C2E739823FAA60ED1E580:6:" | gpg --import-ownertrust

export OPENVAS_GNUPG_HOME=/etc/openvas/gnupg

sudo mkdir -p $OPENVAS_GNUPG_HOME

sudo cp -r /tmp/openvas-gnupg/* $OPENVAS_GNUPG_HOME/

sudo chown -R gvm:gvm $OPENVAS_GNUPG_HOME
```

Configuration de sudo pour la numérisation

Pour l'analyse des vulnérabilités, il est nécessaire de disposer de plusieurs fonctionnalités pour lesquelles seuls les utilisateurs root sont autorisés, par exemple la création de sockets bruts. Par conséquent, une configuration sera ajoutée pour permettre aux utilisateurs du groupe gvm d'exécuter l'application openvas-scanner en tant qu'utilisateur root via sudo.

```
sudo visudo
...
# allow users of the gvm group run openvas
%gvm ALL = NOPASSWD: /usr/local/sbin/openvas
```

Configuration de PostgreSQL

Le système de gestion de base de données PostgreSQL est utilisé comme stockage central pour les informations sur les utilisateurs et les analyses. gvmd se connecte à une base de données PostgreSQL et interroge les données. Cette base de données doit être créée et configurée.

```
sudo apt install -y postgresql
sudo systemctl start postgresql@14-main
sudo -u postgres bash
cd
createuser -DRS gvm
createdb -O gvm gvmd
psql gvmd -c "create role dba with superuser noinherit; grant dba to gvm;"
exit
```

Configuration d'un utilisateur administrateur

Pour accéder et configurer les données de vulnérabilité, un utilisateur administrateur doit être créé. Cet utilisateur peut se connecter via l'interface Web de Greenbone Security Assistant (GSA). Ils

auront accès à toutes les données et seront ensuite configurés pour agir en tant que Feed Import Owner.

```
/usr/local/sbin/gvmd --create-user=admin

/usr/local/sbin/gvmd --create-user=admin --password=<password>
```

Configuration des services pour Systemd

Systemd est utilisé pour démarrer les démons ospd-openvas, gvmd et gsad. Par conséquent, des fichiers de service sont requis.

```
cat << EOF > $BUILD_DIR/ospd-openvas.service

[Unit]

Description=OSPd Wrapper for the OpenVAS Scanner (ospd-openvas)

Documentation=man:ospd-openvas(8) man:openvas(8)

After=network.target networking.service redis-server@openvas.service mosquitto.service

Wants=redis-server@openvas.service mosquitto.service notus-scanner.service

ConditionKernelCommandLine=!recovery

[Service]

Type=exec

User=gvm

Group=gvm

RuntimeDirectory=ospd

RuntimeDirectoryMode=2775

PIDFile=/run/ospd/ospd-openvas.pid

ExecStart=/usr/local/bin/ospd-openvas --foreground --unix-socket /run/ospd/ospd-
openvas.sock --pid-file /run/ospd/ospd-openvas.pid --log-file /var/log/gvm/ospd-openvas.log --
lock-file-dir /var/lib/openvas --socket-mode 0o770 --mqtt-broker-address localhost --mqtt-
broker-port 1883 --notus-feed-dir /var/lib/notus/advisories

SuccessExitStatus=SIGKILL

Restart=always

RestartSec=60
```

```
[Install]
WantedBy=multi-user.target
EOF
sudo cp -v $BUILD_DIR/ospd-openvas.service /etc/systemd/system/
```

```
cat << EOF > $BUILD_DIR/gvmd.service
[Unit]
Description=Greenbone Vulnerability Manager daemon (gvmd)
After=network.target networking.service postgresql.service ospd-openvas.service
Wants=postgresql.service ospd-openvas.service
Documentation=man:gvmd(8)
ConditionKernelCommandLine=!recovery
[Service]
Type=exec
User=gvm
Group=gvm
PIDFile=/run/gvmd/gvmd.pid
RuntimeDirectory=gvmd
RuntimeDirectoryMode=2775
ExecStart=/usr/local/sbin/gvmd --foreground --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=gvm
Restart=always
TimeoutStopSec=10
[Install]
WantedBy=multi-user.target
EOF
sudo cp -v $BUILD_DIR/gvmd.service /etc/systemd/system/
```

```
cat << EOF > $BUILD_DIR/gsad.service
[Unit]
Description=Greenbone Security Assistant daemon (gsad)
Documentation=man:gsad(8) https://www.greenbone.net
After=network.target gvmd.service
Wants=gvmd.service
[Service]
Type=exec
User=gvm
Group=gvm
RuntimeDirectory=gsad
RuntimeDirectoryMode=2775
PIDFile=/run/gsad/gsad.pid
ExecStart=/usr/local/sbin/gsad --foreground --listen=127.0.0.1 --port=9392 --http-only
Restart=always
TimeoutStopSec=10
[Install]
WantedBy=multi-user.target
Alias=greenbone-security-assistant.service
EOF
sudo cp -v $BUILD_DIR/gsad.service /etc/systemd/system/
```

```
sudo systemctl daemon-reload
```

Synchronisation des flux

Pour l'analyse des vulnérabilités proprement dite, des scripts de test de vulnérabilité, des informations de sécurité telles que les CVE, les listes de ports et les configurations d'analyse sont requis. Toutes ces données sont fournies par le Greenbone Community Feed (GCF) et doivent être téléchargées initialement avant de démarrer les services.

Une synchronisation se compose toujours de deux parties : Téléchargement des modifications via Rsync et Chargement des modifications en mémoire et dans une base de données par un deamon.

Ce n'est que si les deux étapes sont terminées que les données synchronisées sont à jour et peuvent être utilisées.

La première étape se fait via le script greenbone-feed-sync. La deuxième étape se fait automatiquement au démarrage des deamons.

Téléchargement des données

Les données téléchargées se composent de quatre types de données différents :

- Données VT
- Données SCAP
- Données CERT
- Données GVMD

Les données VT contiennent des fichiers .nasl et .notus pour créer des résultats lors d'une analyse de vulnérabilité. Les fichiers .nasl sont traités par OpenVAS Scanner et les fichiers .notus par Notus Scanner.

Les données SCAP contiennent des informations CPE et CVE.

Les données CERT contiennent des informations sur les vulnérabilités provenant des agences allemandes DFN-CERT et CERT-Bund.

Les données GVMD (ou également appelées « objets de données ») sont des configurations d'analyse, des politiques de conformité, des listes de ports et des formats de rapport.

```
sudo /usr/local/bin/greenbone-feed-sync
```

Démarrage des services Greenbone Community Edition

```
sudo systemctl start ospd-openvas
sudo systemctl start gvmd
sudo systemctl start gsad
sudo systemctl enable ospd-openvas
sudo systemctl enable gvmd
sudo systemctl enable gsad
sudo systemctl status ospd-openvas
sudo systemctl status gvmd
sudo systemctl status gsad
```

Données des tests de vulnérabilité

Lorsque gvmd a fini de charger toutes les données, nous avons les messages suivant dans /var/log/gvm/gvmd.log :

```
md manage:   INFO:2023-10-09 01h34.58 UTC:33579: sync_cert: Updating CERT info succeeded.
```

```
md manage:   INFO:2023-10-09 02h09.28 UTC:33577: Updating Max CVSS for DFN-CERT
md manage:   INFO:2023-10-09 02h09.47 UTC:33577: Updating DFN-CERT CVSS max succeeded.
md manage:   INFO:2023-10-09 02h09.47 UTC:33577: Updating Max CVSS for CERT-Bund
md manage:   INFO:2023-10-09 02h09.57 UTC:33577: Updating CERT-Bund CVSS max succeeded.
md manage:   INFO:2023-10-09 02h10.08 UTC:33577: update_scap_end: Updating SCAP info succeeded
```

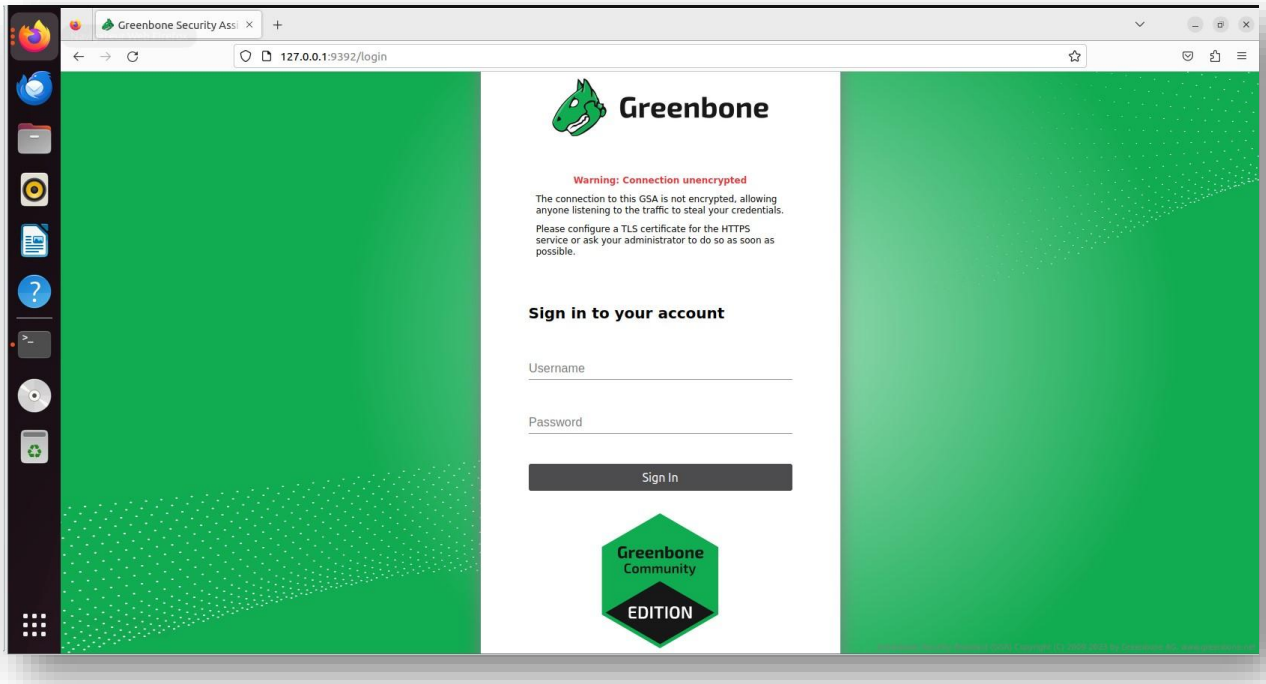
```
md manage:   INFO:2023-10-09 02h20.59 UTC:34540: Updating VTs in database ... done (86750 VTs).
```

Démarrage de la gestion des vulnérabilités

Une fois les services démarrés et toutes les données chargées, l'interface Web de Greenbone Security Assistant – GSA – peut être ouverte dans le navigateur.

```
xdg-open "http://127.0.0.1:9392" 2>/dev/null >/dev/null &
```

Nous pouvons ainsi accéder à l’interface de connexion avec le port 9392 :



Capture 1: Interface de connexion

1.4. Configuration de Greenbone Community Edition

1.4.1. Scan de vulnérabilité

Sur GCE, il est possible d'effectuer deux types de scans de vulnérabilité : authenticated scans and unauthenticated scans.

- Authenticated scans : les scans authentifiés consistent à analyser un système ou un hôte en utilisant des informations d'authentification. Cela signifie que vous fournissez des identifiants d'utilisateur (par exemple, nom d'utilisateur et mot de passe) qui permettent à GVM d'accéder au système avec des privilèges d'utilisateur. Ces informations d'authentification sont utilisées pour se connecter au système cible.
  Ils offrent une visibilité plus complète des vulnérabilités potentielles sur un système, car ils permettent d'accéder à des informations spécifiques qui ne sont généralement disponibles qu'avec des privilèges d'utilisateur.

Ils peuvent identifier des vulnérabilités de configuration, des correctifs manquants et des problèmes spécifiques à un utilisateur qui sont invisibles pour les scans non authentifiés

- Unauthenticated scans : Les scans non authentifiés sont des scans de vulnérabilité qui analysent un système ou un hôte sans utiliser d'informations d'authentification. Cela signifie que le scan ne nécessite pas de fournir des identifiants d'utilisateur ou de mot de passe pour accéder au système cible. Ils sont utiles pour une évaluation générale de la sécurité des systèmes et la détection de vulnérabilités visibles depuis l'extérieur du système.

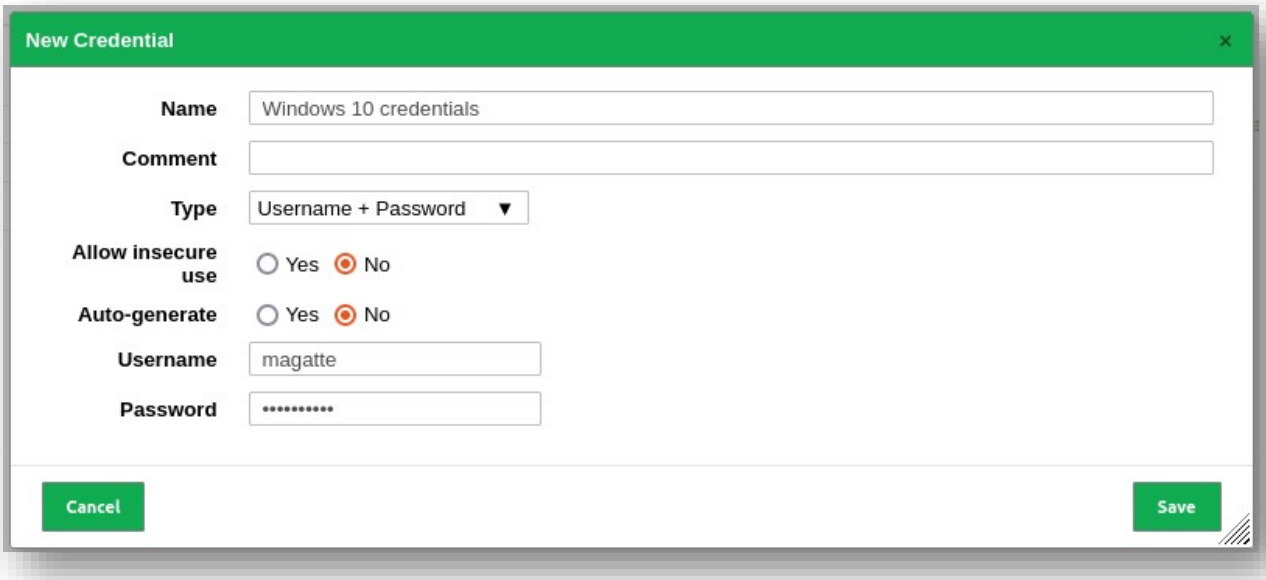
Avant de créer un scan de vulnérabilité avec Greenbone Vulnerability Management (GVM), il est essentiel de configurer un ensemble de fonctionnalités (ou "Features" en anglais) pour que le scan soit efficace et réponde aux besoins de notre environnement.

1.4.1.1. Ajout des Targets

L'ajout des targets représentent une étape importante parce qu'ils représentent les assets sur lesquels les scans sont faits. Il est possible d'ajouter un Target avec ses credentials pour effectuer des scans authentifiés ou sans pour effectuer des scans non authentifiés.

Nous pouvons ajouter de nouveaux credentials depuis Configuration puis credentials.

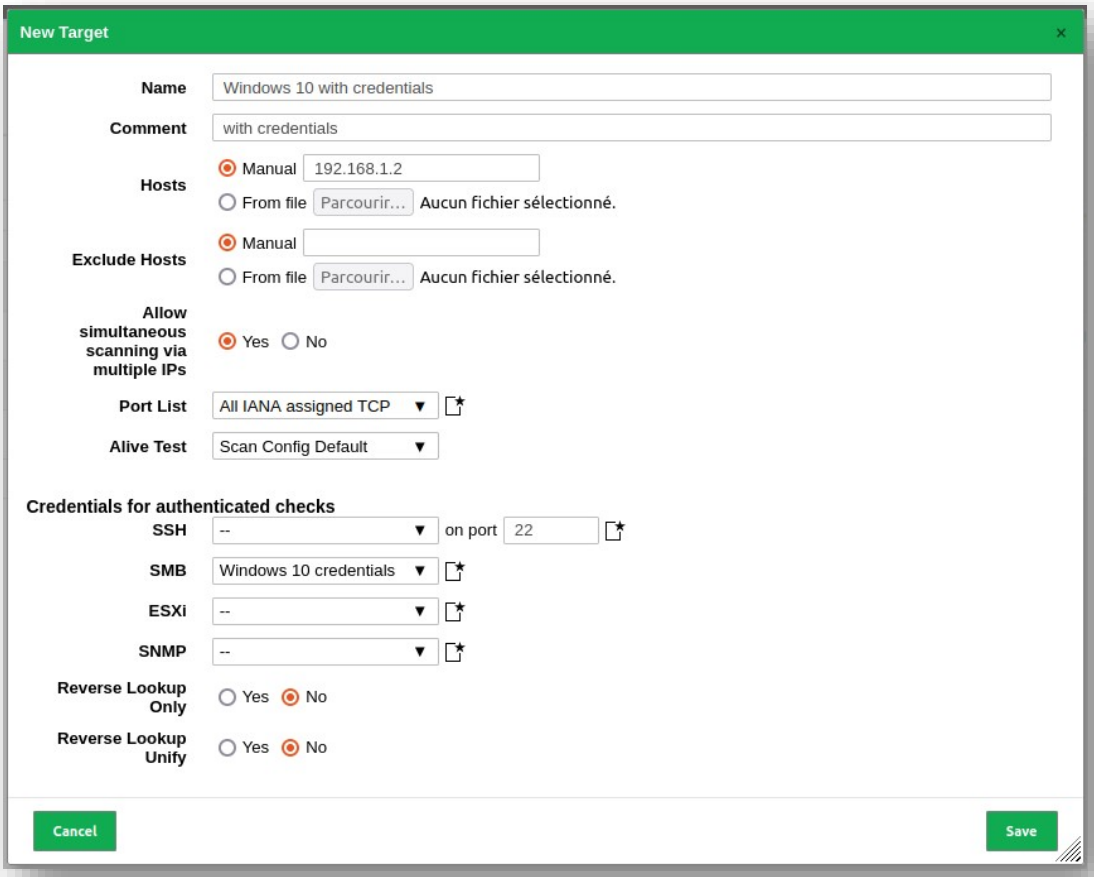
La capture ci-après montre l'ajout de nouvelles données d'identification relatives à notre machine Windows 10. Il est possible de préciser le type de données (nom d'utilisateur et mot de passe, clé ssh ou encore certificat) ainsi que leur valeur.



Capture 2: Création de credentials

On peut ajouter un target à partir de Configuration puis Targets.

La capture ci-après représente la création d'un Target (notre machine Windows 10). Nous avons renseigné lors de la création l'adresse IP, la liste des ports qui seront scannés, les credentials précédemment créés…



Capture 3: Création d'une nouvelle Target

1.4.1.2. Création d'une tâche de scan

Un test de scanning basique a été réalisé dans cette partie où les étapes et résultats sont décrits et affichés à l'aide de captures d'écran.

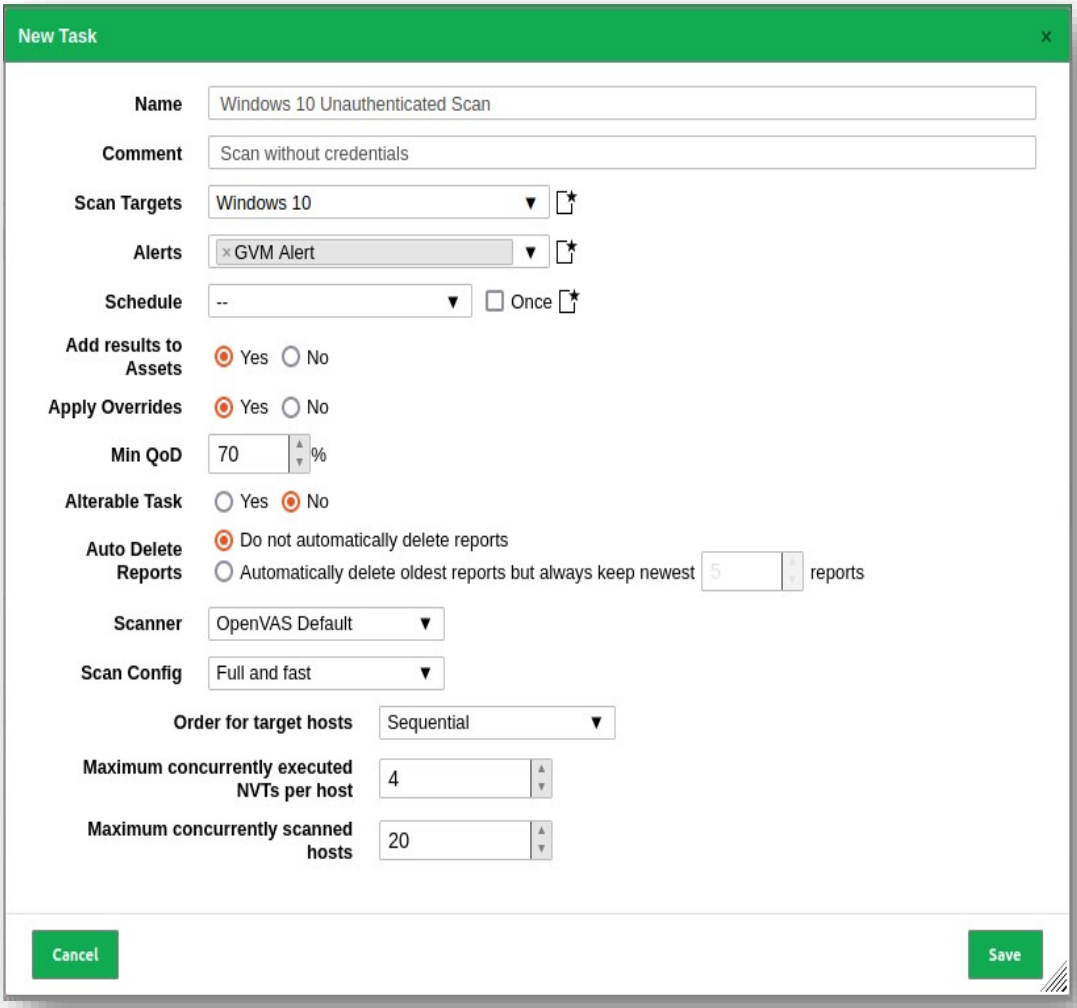
L'asset analysé pour ce test est la machine Windows 10 dans notre architecture.

Afin de performer un scan, nous allons créer une nouvelle tâche dans Scans puis Tasks.

Dans ce test nous allons effectuer les deux types de scan décrits plus hauts.

- **Création task**

Lors de la création de la tâche on précise le target qui doit être scanné. S'il s'agit d'un scan authentifié on choisit le target avec les identifiants et s'il s'agit d'un scan non authentifié on choisit le target sans les identifiants.



Capture 4: Création d'une tâche de scan

- **Lancement du scan dans le menu 'Actions'**

Name ▲	Status	Reports	Last Report	Severity	Trend	Actions
Metasploitable Authenticated Scan	New					
Metasploitable Unauthenticated Scan	New					
Windows 10 Authenticated Scan (Scan with credentials)	New					
Windows 10 Unauthenticated Scan (Scan without credentials)	New					
Windows Server Authenticated Scan	New					
Windows Server Unauthenticated Scan	New					

Capture 5: Liste des différentes tâches créées

Après avoir créé la tâche, elle apparaît dans la liste Tasks. Pour le lancer, on clique sur l'icône Play à droite.

- **Rapports**

Au début du scan, le statut de la tâche est à 'Requested' et à la fin il est à 'Done'. Nous voyons sur la capture qui suit le résultat des deux types de scans effectués sur un même asset.

Windows 10 Authenticated Scan (Scan with credentials)	Done	2	Fri, Oct 13, 2023 8:26 PM UTC	10.0 (High)		
Windows 10 Unauthenticated Scan (Scan without credentials)	Done	1	Fri, Oct 13, 2023 7:39 PM UTC	5.0 (Medium)		

Capture 6: Liste des différentes tâches créées

Dans l'onglet Severity (Gravité la plus élevée trouvée par une analyse de la tâche), nous avons deux valeurs différentes.

Une fois le scan terminé, nous pouvons accéder aux résultats en cliquant sur le lien qui mène au rapport.

Rapport du scan non authentifié :

Report:Fri, Oct 13, 2023 7:39 PM UTC Done

ID: 5f5af7fa-9a49-4902-af23-e676779c4d02 Created: Fri, Oct 13, 2023 7:39 PM UTC Modified: Fri, Oct 13, 2023 7:51 PM UTC Owner: admin

Information | Results (2 of 16) | Hosts (1 of 1) | Ports (1 of 4) | Applications (0 of 0) | Operating Systems (1 of 1) | CVEs (1 of 1) | Closed CVEs (7 of 7) | TLS Certificates (0 of 0) | Error Messages (0 of 0) | User Tags (0)

1 - 2 of 2

Vulnerability	Severity ▼	QoD	Host IP	Host Name	Location	Created
DCE/RPC and MSRPC Services Enumeration Reporting	5.0 (Medium)	80 %	192.168.1.2		135/tcp	Fri, Oct 13, 2023 7:47 PM UTC
ICMP Timestamp Reply Information Disclosure	2.1 (Low)	80 %	192.168.1.2		general/icmp	Fri, Oct 13, 2023 7:44 PM UTC

(Applied filter: apply_overrides=0 levels=hml rows=100 min_qod=70 first=1 sort-reverse=severity)

1 - 2 of 2

Capture 7: Résultat du scan non authentifié

Rapport du scan authentifié :

Report:Fri, Oct 13, 2023 8:26 PM UTC Done

ID: db5e50af-3bff-4567-878e-2a16a68c5302 Created: Fri, Oct 13, 2023 8:26 PM UTC Modified: Fri, Oct 13, 2023 9:17 PM UTC Owner: admin

Information | Results (132 of 167) | Hosts (1 of 1) | Ports (1 of 4) | Applications (21 of 21) | Operating Systems (1 of 1) | CVEs (128 of 128) | Closed CVEs (3955 of 3955) | TLS Certificates (0 of 0) | Error Messages (0 of 0) | User Tags (0)

1 - 100 of 132

Vulnerability	Severity ▼	QoD	Host IP	Host Name	Location	Created
Mozilla Firefox Security Update(mfsa_2023-18_2023-20)-Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates(mfsa2022-24) - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates(mfsa_2023-04_2023-06)-Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates(mfsa_2023-04_2023-06)-Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates (mfsa2023-13) - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Microsoft Windows Server Message Block 3.1.1 RCE Vulnerability (KB4551762)	10.0 (High)	80 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 9:10 PM UTC
Mozilla Firefox Security Updates(mfsa2022-10) - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates(mfsa_2023-07_2023-11)-Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates (mfsa_2023-22_2023-24) - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates (mfsa_2023-26_2023-31) - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Update(mfsa_2022-09) - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates(mfsa_2023-16_2023-17)-Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates(mfsa2022-16) - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Mozilla Firefox Security Updates(mfsa2022-19) - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:52 PM UTC
Adobe Reader Sandbox Bypass Vulnerability (Aug 2014) - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:51 PM UTC
Microsoft Windows Multiple Vulnerabilities (KB4565483)	10.0 (High)	80 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 9:08 PM UTC
Adobe Reader Multiple Vulnerabilities - Windows	10.0 (High)	97 %	192.168.1.2	DESKTOP-JPCACNC	general/tcp	Fri, Oct 13, 2023 8:51 PM UTC

Capture 8: Résultat du scan authentifié

Nous remarquons une nette différence entre les résultats des deux types de scans. Le premier a réussi à trouver au total 16 vulnérabilités contre 167 pour le second. En parcourant la liste du second, nous remarquons que nous avons plusieurs types de vulnérabilités, beaucoup étant relatives aux logiciels installés sur l'asset ainsi qu'aux paramètres définis.

Sur la page Results nous pouvons voir la liste de toutes vulnérabilités trouvées sur l'asset, leur gravité basé sur le CVSS, leur QoD, l'hôte sur lequel la vulnérabilité a été trouvée ainsi que le numéro et type de port utilisé pour trouver la vulnérabilité.

La qualité de détection (QoD) est une valeur comprise entre 0 % et 100 % décrivant la fiabilité de la détection de vulnérabilité ou de la détection de produit exécutée. Par défaut, seuls les résultats détectés par les VT avec une QoD de 70 % ou plus sont affichés. Le filtre peut être ajusté pour afficher les résultats avec une QoD inférieure.

Pour interpréter les résultats, il est essentiel de prendre en compte les éléments suivants :

- Faux positifs ou false_positives :

  Un faux positif est un résultat qui décrit un problème qui n'existe pas réellement. Les scanners de vulnérabilité trouvent souvent des preuves indiquant une vulnérabilité, mais un jugement final ne peut pas être porté. Deux options sont disponibles :

  - Signalement d'une vulnérabilité potentiellement inexistante (faux positif).
  - Ignorer le signalement d'une vulnérabilité potentiellement existante (faux négatif).

  Puisqu'un utilisateur peut identifier, gérer et ainsi traiter les faux positifs par rapport aux faux négatifs, le scanner de vulnérabilités de l'appliance signale toutes les vulnérabilités potentiellement existantes. Si l'utilisateur sait qu'il existe des faux positifs, un remplacement peut être configuré.
- Plusieurs résultats peuvent avoir la même cause :

  Si un progiciel particulièrement ancien est installé, plusieurs vulnérabilités existent souvent. Chacune de ces vulnérabilités est testée par un VT individuel et provoque une alerte. L'installation d'un package actuel supprimera de nombreuses vulnérabilités à la fois.
- High (haut) et Medium (moyen) :

  Les résultats des niveaux de gravité Élevé et Moyen sont les plus importants et doivent être traités en priorité. Avant d'aborder les constatations de niveau moyen, il convient d'aborder les constatations de haut niveau. Ce n'est que dans des cas exceptionnels qu'il convient de s'écarter de cette approche, par exemple si l'on sait que les résultats de haut niveau doivent être moins pris en compte parce que le service n'est pas accessible via le pare-feu.
- Low (bas) et Log :

Les résultats des niveaux de gravité Low et Log sont surtout intéressants pour la compréhension détaillée. Ces résultats sont filtrés par défaut mais peuvent contenir des informations très intéressantes. Les prendre en compte augmentera la sécurité du réseau et des systèmes. Souvent, une connaissance plus approfondie de l'application est nécessaire pour leur compréhension. Un résultat typique avec le journal de gravité est qu'un service utilise une bannière avec son nom et son numéro de version. Cela pourrait être utile pour un attaquant lorsque cette version présente une vulnérabilité connue.

1.4.2. Configuration des alertes

La configuration des alertes est une étape essentielle de la gestion des vulnérabilités avec Greenbone Vulnerability Management (GVM). Ces alertes nous aident à être informés des problèmes de sécurité et des vulnérabilités découvertes lors des analyses.

- Définition des Alertes : Les alertes sont des notifications générées par GVM pour vous informer des résultats des analyses, des vulnérabilités détectées et des problèmes de sécurité. Elles vous avertissent lorsque des actions sont nécessaires pour remédier aux vulnérabilités.
- Personnalisation des Alertes : Bien que les valeurs par défaut des alertes dans l'appliance GVM soient généralement appropriées pour de nombreux environnements, nous pouvons personnaliser ces alertes en fonction de vos besoins spécifiques. Les raisons de personnaliser les alertes incluent : le seuil de Sévérité, la fréquence des Alertes, les destinataires des Alertes ou encore le canal de livraison des mails.
- Maintenance Préventive : Les alertes vous informent des vulnérabilités, mais il est essentiel d'adopter des pratiques de maintenance préventive pour résoudre ces vulnérabilités. Vous pouvez configurer des alertes pour inclure des recommandations de correctifs et des actions à prendre pour remédier aux vulnérabilités.
- Rapports d'Alertes : Nous pouvons également configurer des rapports d'alertes qui fournissent un résumé des vulnérabilités détectées sur une base régulière. Ces rapports sont utiles pour une surveillance continue de la sécurité.

Pour les besoins de ce travail, nous avons configuré le service Postfix sur notre serveur Greenbone pour la gestion des courriels générés par les rapports de scans de vulnérabilité. La configuration de Postfix permet à notre serveur de générer et d'envoyer automatiquement des rapports par e-mail à l'équipe de sécurité ou aux administrateurs du réseau dès qu'un scan est terminé.

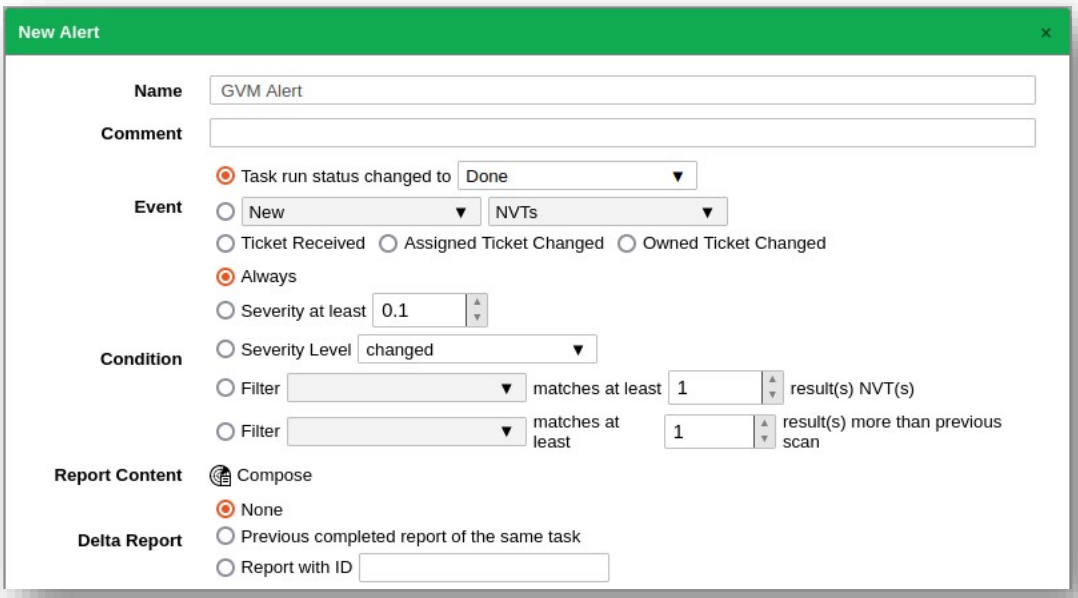
Le service a été configuré pour envoyer des mails avec le serveur SMTP de gmail à partir de l'adresse greenbone.gce@gmail.com.

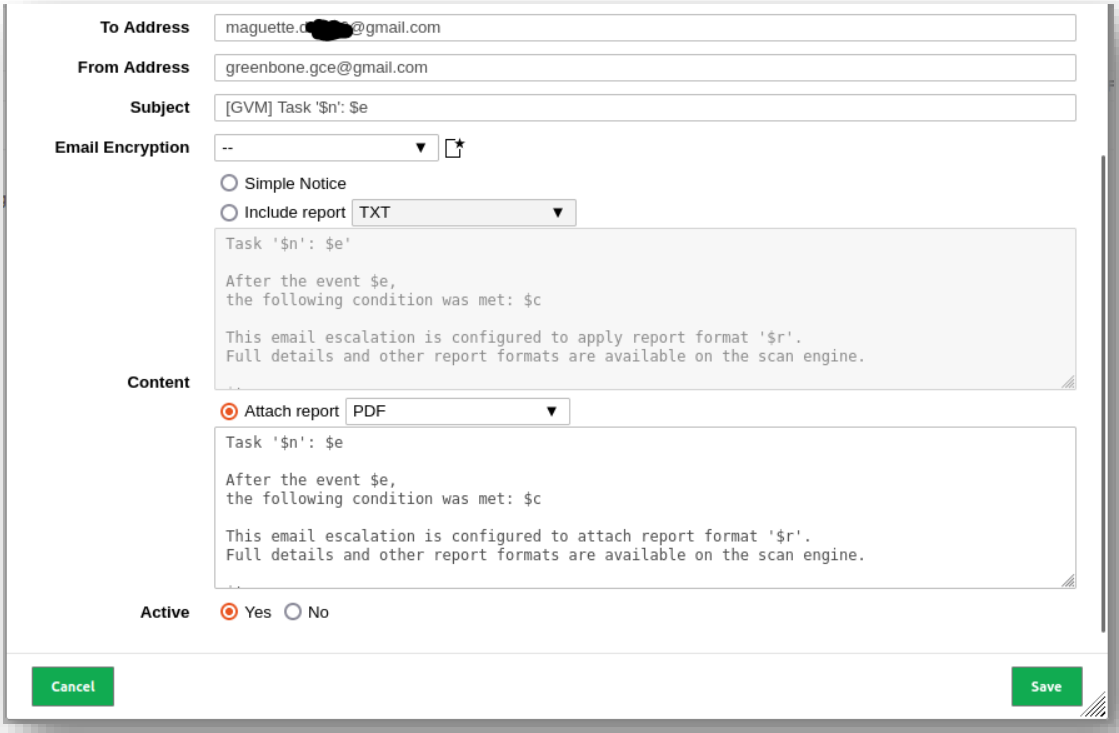
```
  GNU nano 6.2                                          /etc/postfix/smtp_sasl_password_map
[smtp.gmail.com]:587 greenbone.gce@gmail.com:zxip[redacted]gwvbm
```

```
root@gse:/etc/postfix/ssl# sudo systemctl status postfix
● postfix.service - Postfix Mail Transport Agent
     Loaded: loaded (/lib/systemd/system/postfix.service; enabled; vendor preset: enabled)
     Active: active (exited) since Thu 2023-10-12 13:28:09 UTC; 6s ago
       Docs: man:postfix(1)
    Process: 50400 ExecStart=/bin/true (code=exited, status=0/SUCCESS)
   Main PID: 50400 (code=exited, status=0/SUCCESS)
        CPU: 3ms

oct. 12 13:28:09 gse systemd[1]: Starting Postfix Mail Transport Agent...
oct. 12 13:28:09 gse systemd[1]: Finished Postfix Mail Transport Agent.
```

Pour créér des alertes, on se rend dans Configuration puis Alerts.





Capture 9: Création d'une alerte par mail

La capture ci-dessus nous montre la création d'une alerte qui lorsqu'elle est associée à une tâche envoie un mail depuis greenbone.gce@gmail.com à une adresse bien définie lorsque le statut de la tâche passe à Done avec comme pièce jointe le rapport.

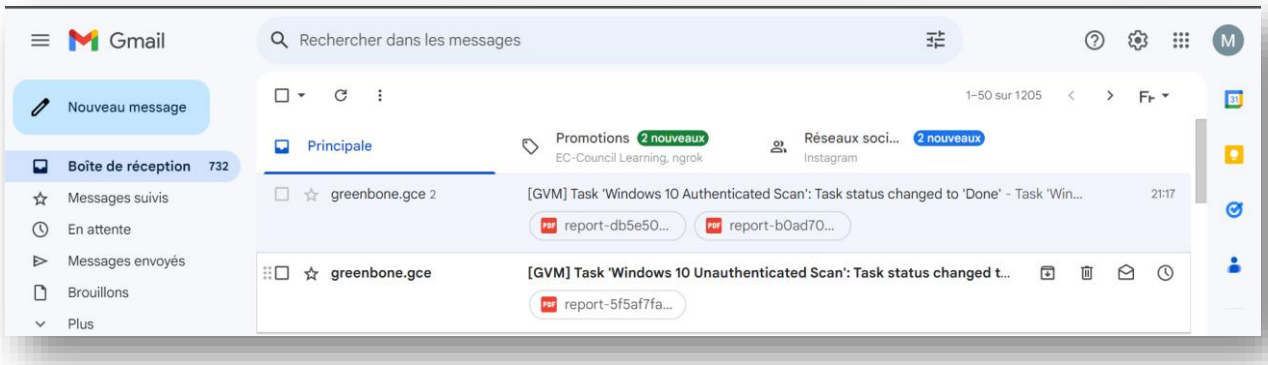


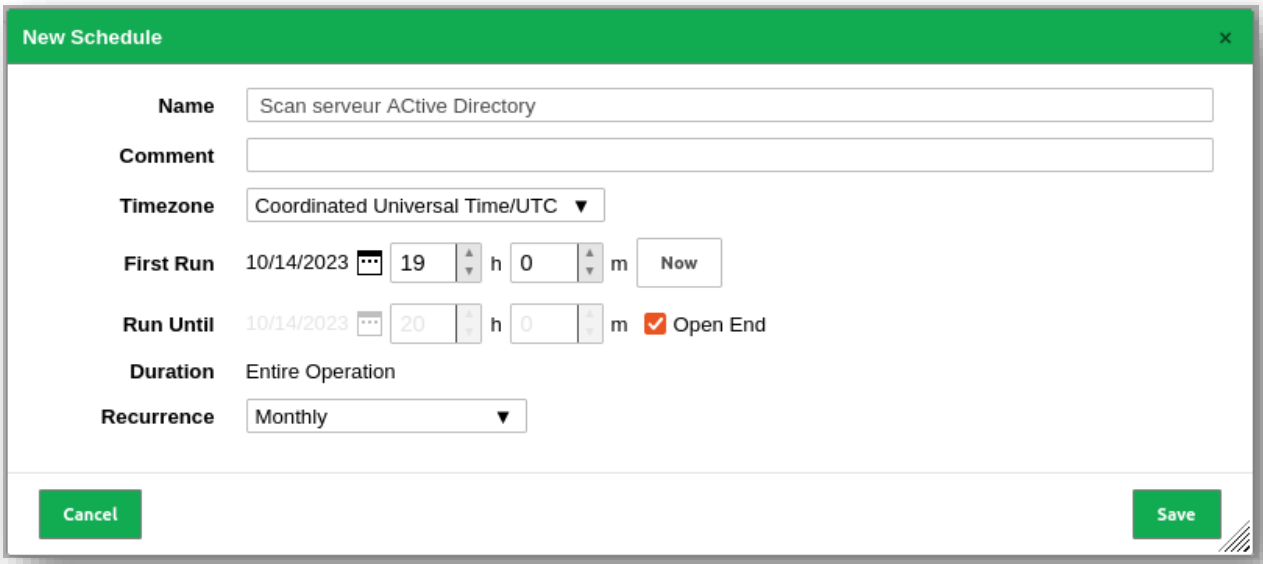
Figure 2: Réception des mails d'alerte

1.4.3. Planifications des scans

La planification des scans de vulnérabilité est une étape importante dans le processus de gestion des vulnérabilités avec Greenbone Vulnerability Management. Elle permet de déterminer quand et comment les scans doivent être exécutés pour répondre aux besoins de l'organisation.

Pour créer une tâche de planification, on se rend dans Configuration puis Schedules.

La capture ci-dessous montre la création d'une nouvelle tâche de planification qui lorsqu'elle sera liée à notre tâche de scan, s'exécutera le 14/10/2023 à 19h et se répétera une fois tous les mois.



Capture 10: Création d'une nouvelle tâche de planification

1.4.4. Comptes utilisateurs et gestion des privilèges

Lors de l'installation de GCE, un utilisateur admin a été créé. Il est possible d'en créer d'autres à partir de l'interface graphique dans Administration puis users.

Nous avons différents rôles qui définissent les autorisations de l'utilisateur :

Admin : Ce rôle a toutes les autorisations par défaut. Il lui est notamment permis de créer et de gérer d'autres utilisateurs, rôles et groupes.

Info : Ce rôle a uniquement un accès en lecture aux informations NVT et SCAP

Guest: Ce rôle correspond au rôle 'Info' mais n'est pas autorisé à modifier les paramètres utilisateur

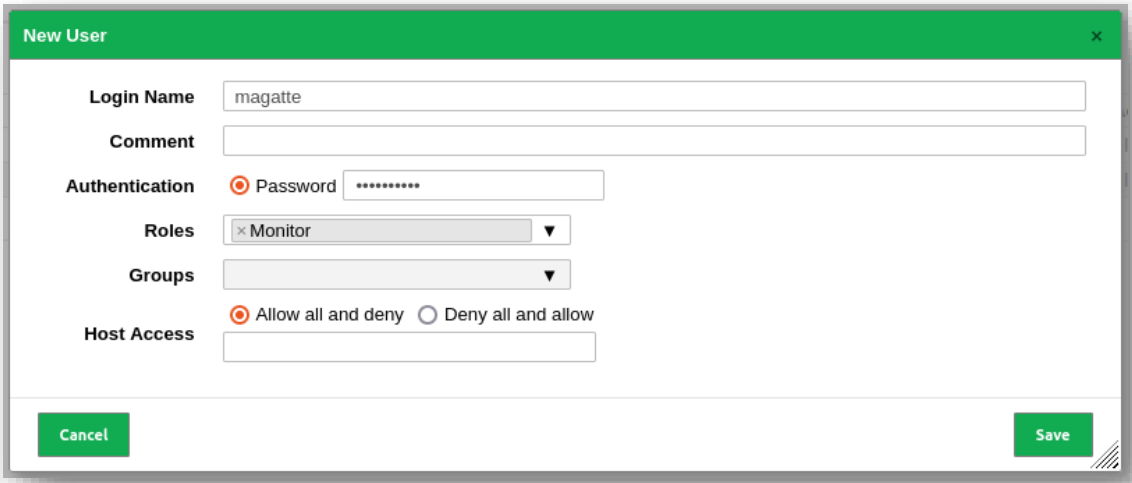
Monitor : Le rôle a accès aux rapports système

Observer: Ce rôle dispose d'un accès en lecture au système, mais n'est pas autorisé à démarrer ou à créer de nouveaux scans. Il n'a qu'un accès en lecture aux scans pour lesquelles il a été défini comme observateur.

User: Ce rôle dispose de toutes les autorisations par défaut, à l'exception de la gestion des utilisateurs, des rôles et des groupes. Ce rôle n'est pas autorisé à synchroniser et gérer les flux. Dans l'interface Web, il n'y a pas d'accès à la page 'Administration"

Super Administrateur : Ce rôle a accès à tous les objets de tous les utilisateurs. Il ne peut pas être configuré dans l'interface Web mais en ligne de commande avec gvmd.

```
Gvmd - -create-user=magatte  - -password=P@ssWay123 - -role=”Super Admin”
```



Capture 11: Création d’un nouvel utilisateur

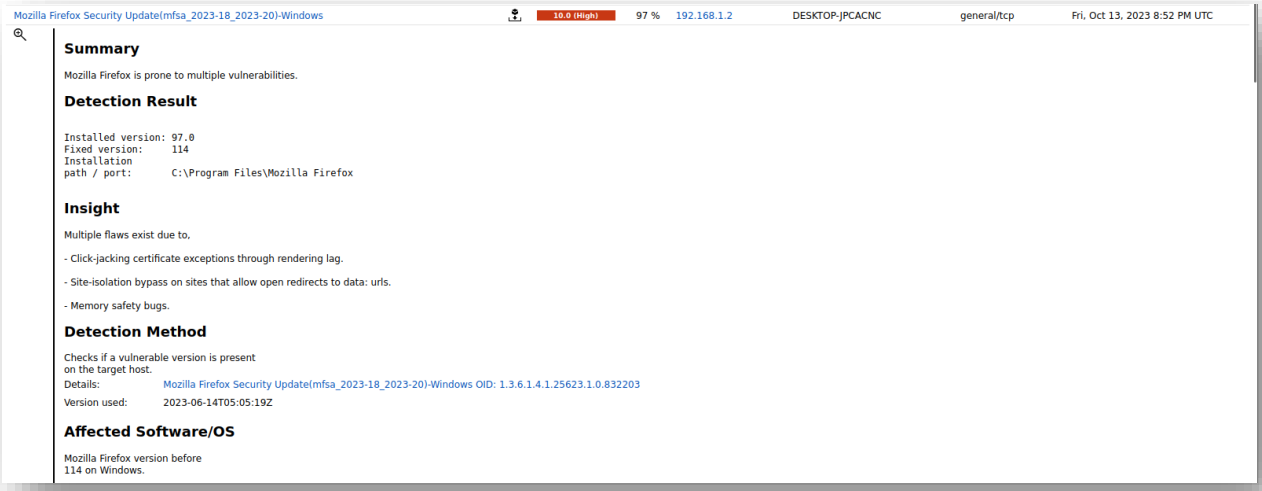
1.4.5. Les tickets de remédiation

On accède à cette section via l'onglet Resilience puis Remédiation tickets. La résilience constitue l'habilité à retourner à un stade normal.

Pour chaque vulnérabilité trouvée sur un rapport, il est possible de l'affecter à un utilisateur sur la plateforme afin qu'il s'occupe de la résolution : on parle de tickets de remédiation.

1.4.5.1. La remédiation

Au niveau des rapports générés, en cliquant sur chacune des vulnérabilités nous avons les informations relatives à cette dernière. On a le CVE associé, la méthode de détection utilisée, le Software/OS qui est affecté… mais aussi une solution pour éliminer cette vulnérabilité.



Impact

Successful exploitation will allow
attackers to execute arbitrary code, bypass security restrictions and
cause denial of service on an affected system

Solution

Solution Type: Vendorfix
Upgrade to Mozilla Firefox version 114
or later, Please see the references for more information.

References

CVE CVE-2023-34414
CVE-2023-34415
CVE-2023-34416
CVE-2023-34417

CERT DFN-CERT-2023-1643
DFN-CERT-2023-1564
DFN-CERT-2023-1340
DFN-CERT-2023-1335
DFN-CERT-2023-1305
WID-SEC-2023-2031
WID-SEC-2023-1414
WID-SEC-2023-1385

Other https://www.mozilla.org/en-US/security/advisories/mfsa2023-20/

Capture 12: Détails des vulnérabilités trouvées

1.4.5.2. Les tickets remédiation

Avec le grand nombre de vulnérabilités qui est découvert, il est nécessaire de savoir déléguer chaque remédiation à une personne habilitée. C'est là qu'interviennent les tickets de remédiation.

Pour créer un ticket de remédiation, on se rend dans Scans puis Results puis on clique sur la vulnérabilité qu'on veut fixer. Sur la page qui se développe, on clique sur l'icône détails et puis on clique sur l'icône en forme de ticket.

Une fenêtre s'ouvre et nous permet d'assigner cette vulnérabilité à un utilisateur qui est sur la plateforme avec un message personnalisé.

Create new Ticket for Result TWiki XSS and Command Execution Vulnerabilities ×

Assign To User magatte ▼

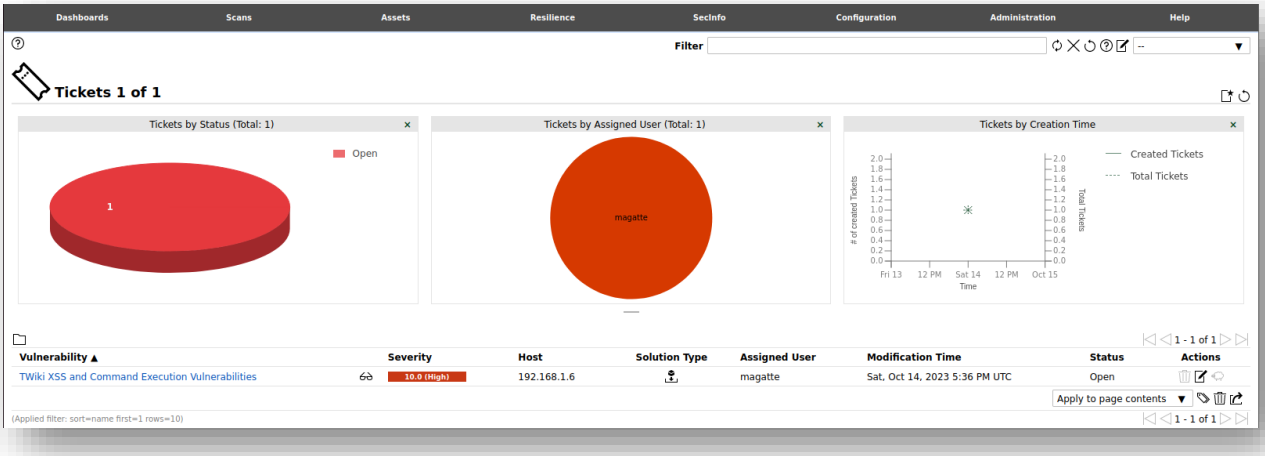
Note Hello Magatte, merci de fixer cette vulnérabilité avant lundi prochain!

Cancel Save

Capture 13: Création d'un nouveau ticket de remédiation

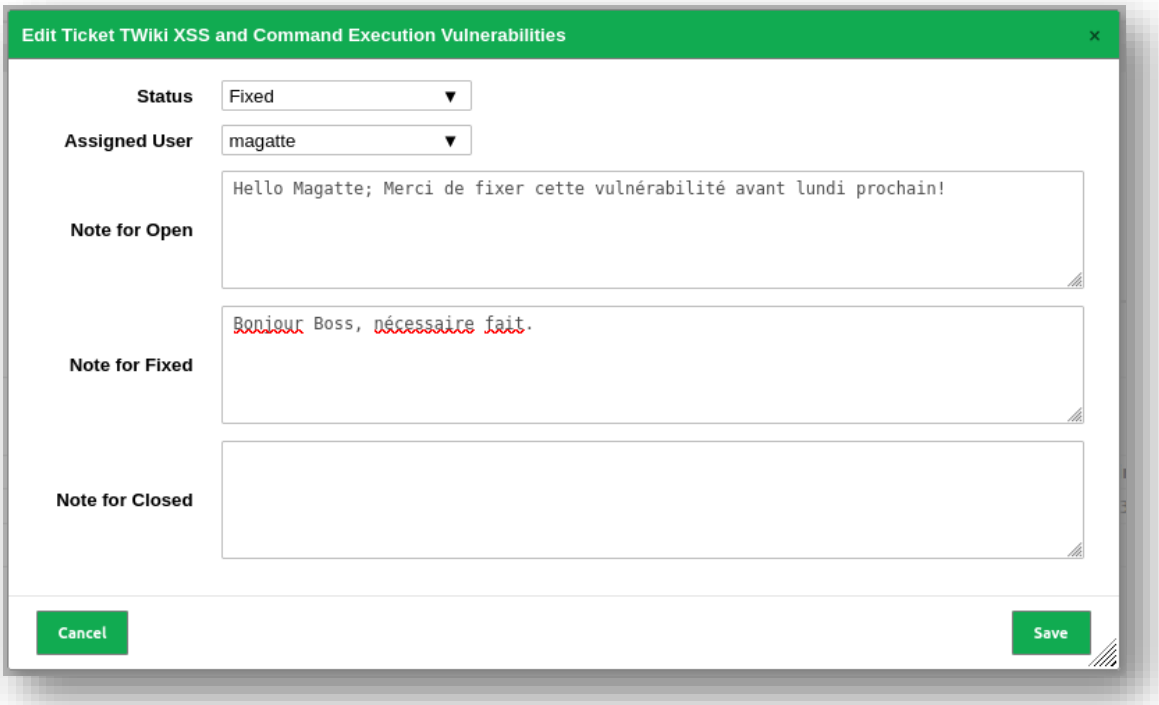
Pour vérifier que le ticket a bien été envoyé à l'utilisateur magatte, nous allons nous connecter avec ce compte et vérifier au niveau de Resilience puis Remédiation Tickets.

La capture ci-dessous montre le ticket qui a été assigné à l'utilisateur magatte.



Capture 14: Liste des tickets assignés à l'utilisateur

Après avoir fixé cette vulnérabilité, l'utilisateur magatte pourra modifier le statut du ticket de open à fixed avec une note. De ce fait, la personne qui avait assigné ce ticket verra que le ticket a été résolu.



Capture 15: Changement de statut d'un ticket

1.4.6. Les scans de conformité

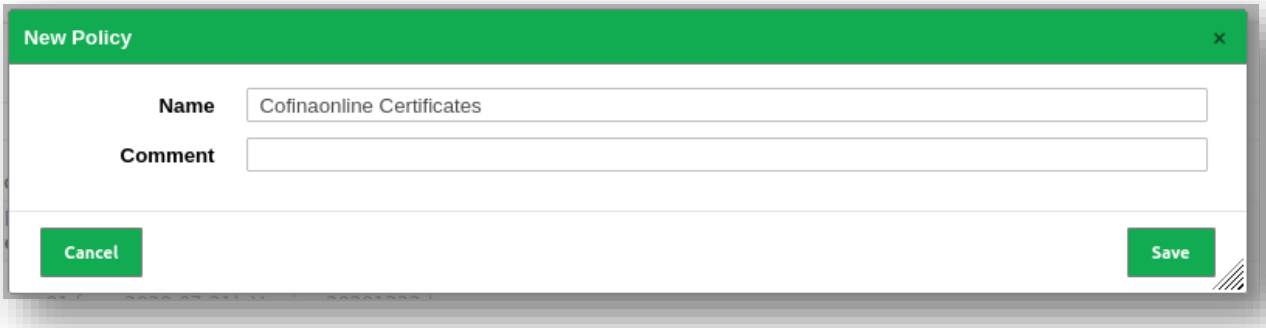
Dans le domaine de la sécurité des technologies de l'information, la conformité constitue l'une des principales approches des organisations pour sécuriser leurs actifs.

Cependant avec la version open source de Greenbone, nous n'avons pas accès à beaucoup de politiques qui permettent de faire des scans de conformité comme PCI DSS, Windows Server Hardening… Pour en bénéficier il faudra les créer une par une en autorisant les paramètres nécessaires.

Pour les besoins de ce travail, nous avons créé une politique qui gére les certitificats SSL/ TLS. Ces derniers ont une date d'expiration. Après cela, l'intégrité des systèmes ou applications n'est plus assurée. De ce fait, en tant qu'administrateur, il est important d'être averti en cas d'expiration ou lorsque cette date approche.

- Création de la politique :

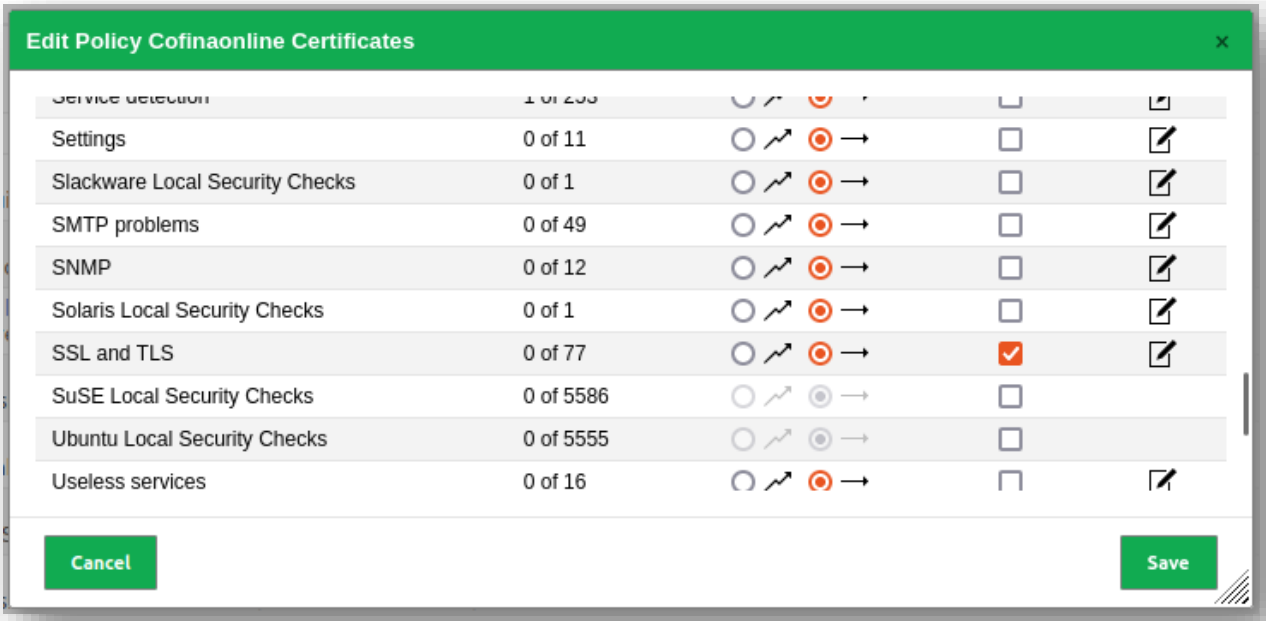
Ici nous avons créé une nouvelle politique nommée ‘Cofinaonline Certificates’ à parir de Resilience puis Compliance Policies.



Capture 16: Création d’une nouvelle politique

Pour pouvoir personnaliser notre politique, on clique sur le bouton Editer à droite de la politique.

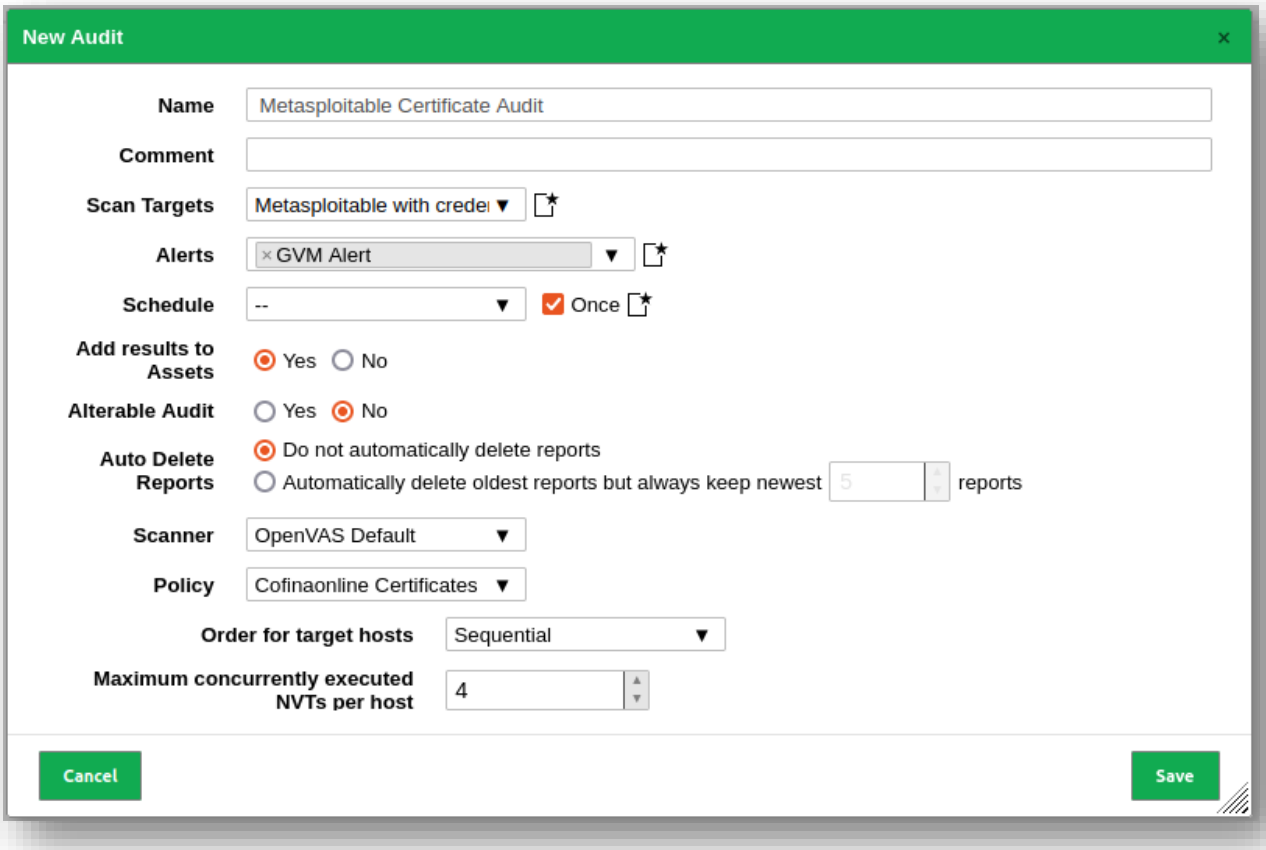
Dans la section ‘Edit Network Vulnerability Test Families’, on sélectionne le bouton radio ‘SSL and TLS’ pour inclure et activer cette famille.



Capture 17: Personnalisation de la politique créée

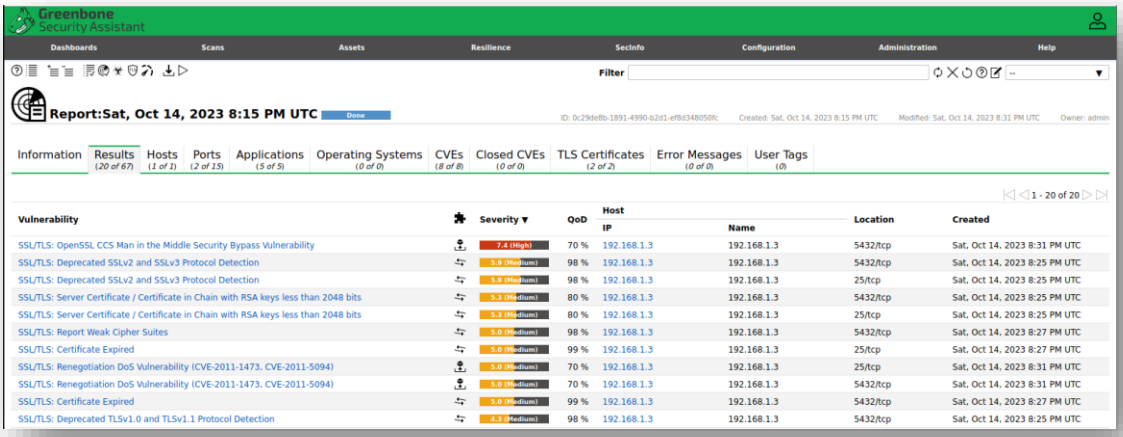
- Réalisation d'un scan de conformité à partir de cette politique :

Dans Resilience puis Compliance Audit, nous allons créer un nouvel audit et l'exécuter en utilisant la politique précédemment créée.



Capture 18: Création d'une nouvelle tâche d'audit

L'exécution de cette politique sur la machine Metasploitable de notre architecture donne les résultats suivants :



Capture 19: Résultats de l'audit sur la machine Metasploitable